BỘ KHOA HỌC VÀ CÔNG NGHỆ
HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG



BÁO CÁO
ĐỒ ÁN MÔN HỌC

MÔN HỌC: PHÂN TÍCH THIẾT KẾ HỆ THỐNG THÔNG TIN

ĐỀ TÀI: HỆ THỐNG QUẢN LÝ QUÉT LỖ HỔNG WEBSITE ĐỊNH KỲ

Giảng viên hướng dẫn: Th.S Nguyễn Thị Bích Nguyên

Thực hiện bởi nhóm sinh viên, bao gồm:

1.	Phạm Anh Tuấn	N23DCAT742	D23CQAT01-N	<Trưởng nhóm>
2.	Đặng Huỳnh Tấn Hiên	N23DCAT022	D23CQAT01-N	<Thành viên>
3.	Lê Quốc Nhi	N23DCAT054	D23CQAT01-N	<Thành viên>

TP.HCM, tháng 9/2026

MỤC LỤC

DANH SÁCH HÌNH VÀ BẢNG.....3
DANH MỤC TỪ VIẾT TẮT.....4
CHƯƠNG I. TỔNG QUAN.....00
1.1. Bối cảnh và lý do chọn đề tài.....00
1.2. Mục tiêu và phạm vi.....00
1.3. Cơ sở lý thuyết và thuật ngữ.....00
1.4. Nền tảng kỹ thuật và tình trạng dự án.....00
CHƯƠNG II. PHÂN TÍCH YÊU CẦU.....00
2.1. Đối tượng sử dụng và trách nhiệm.....00
2.2. Quy trình nghiệp vụ tổng thể.....00
2.3. F-01 Quản lý tài sản và phạm vi quét.....00
2.4. F-02 Lập lịch và điều phối quét.....00
2.5. F-03 Tiếp nhận báo cáo và phát hiện.....00
2.6. F-04 Khắc phục và xác minh.....00
2.7. Yêu cầu dữ liệu và yêu cầu chất lượng.....00
CHƯƠNG III. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG.....00
3.1. Ranh giới hệ thống.....00
3.2. Ca sử dụng.....00
3.3. Luồng hoạt động và trạng thái.....00
3.4. Kiến trúc hệ thống.....00
3.5. Thiết kế dữ liệu và sơ đồ quan hệ.....00
3.6. Quan hệ giữa các thực thể và các bảng.....00
3.7. Thiết kế giao diện và kiểm soát quyền.....00
CHƯƠNG IV. PHÁT TRIỂN VÀ THỰC THI.....00
4.1. Cấu trúc mã nguồn và các thành phần đã xây dựng.....00
4.2. Luồng điều phối OWASP ZAP trong mã nguồn.....00
4.3. Cơ sở dữ liệu và quản lý thay đổi.....00
4.4. Kiểm thử và mức độ hoàn thành.....00
CHƯƠNG V. TRIỂN KHAI VÀ KIỂM CHỨNG.....00
5.1. Môi trường và điều kiện triển khai.....00
5.2. Trình tự triển khai.....00
5.3. Bảo mật, giám sát và sao lưu.....00
5.4. Kịch bản kiểm chứng và tiêu chí nghiệm thu.....00
CHƯƠNG VI. KẾT LUẬN.....00
6.1. Kết quả đạt được.....00
6.2. Hạn chế hiện tại.....00
6.3. Hướng hoàn thiện.....00

DANH SÁCH HÌNH VÀ BẢNG

Hình 2.1. Luồng hoạt động từ tài sản đến xác minh.....00
Hình 3.1. Sơ đồ ca sử dụng lõi của HTQLHDK.....00
Hình 3.2. Kiến trúc logic và luồng tích hợp ZAP.....00
Hình 3.3. Sơ đồ quan hệ người dùng, tài sản và phạm vi.....00
Hình 3.4. Sơ đồ quan hệ kế hoạch và lần quét.....00
Hình 3.5. Sơ đồ quan hệ phát hiện, khắc phục và xác minh.....00
Bảng ký hiệu và chữ viết tắt.....00
Bảng 1.1. Mục tiêu của bốn chức năng chính.....00
Bảng 1.2. Nền tảng và trạng thái hiện tại.....00
Bảng 2.1. Tác nhân và trách nhiệm.....00
Bảng 2.2. Luồng xử lý F-01.....00
Bảng 2.3. Luồng xử lý F-02.....00
Bảng 2.4. Luồng xử lý F-03.....00
Bảng 2.5. Luồng xử lý F-04.....00
Bảng 2.6. Dữ liệu vào ra của các chức năng.....00
Bảng 3.1. Ranh giới và trao đổi dữ liệu.....00
Bảng 3.2. Các ca sử dụng chính.....00
Bảng 3.3. Trạng thái và điều kiện chuyển của lần quét.....00
Bảng 3.4. Trách nhiệm của các thành phần kiến trúc.....00
Bảng 3.5. Danh sách 13 bảng của mô hình đích.....00
Bảng 3.6. Bội số và khóa ngoại giữa các bảng.....00
Bảng 3.7. Màn hình nghiệp vụ ưu tiên.....00
Bảng 4.1. Hiện vật phần mềm và khả năng đã có.....00
Bảng 4.2. Kiểm soát trong luồng Worker.....00
Bảng 4.3. Ma trận mức độ hoàn thành.....00
Bảng 5.1. Ma trận môi trường triển khai.....00
Bảng 5.2. Các bước triển khai và kiểm tra.....00
Bảng 5.3. Kịch bản kiểm chứng bắt buộc.....00

DANH MỤC TỪ VIẾT TẮT

Bảng ký hiệu và chữ viết tắt

Ký hiệu	Diễn giải
HTQLHDK	Hệ thống quản lý quét lỗ hổng website định kỳ
ATTT	An toàn thông tin
ZAP	OWASP Zed Attack Proxy
API	Giao diện lập trình ứng dụng
ERD	Sơ đồ thực thể và quan hệ
OIDC	OpenID Connect
PK / FK	Khóa chính / khóa ngoại
UAT	Kiểm thử chấp nhận của người dùng

CHƯƠNG I. TỔNG QUAN

1.1. Bối cảnh và lý do chọn đề tài

Website của một đơn vị thay đổi liên tục về mã nguồn, thư viện, cấu hình và phạm vi phục vụ. Một báo cáo quét riêng lẻ chỉ cho biết tình trạng ở thời điểm chạy; nếu thiếu hồ sơ tài sản, lịch quét, người chịu trách nhiệm và lịch sử xử lý thì rất khó xác định lỗ hổng nào còn tồn tại, đã tái xuất hiện hoặc đã được khắc phục. Đề tài HTQLHDK giải quyết nhu cầu quản lý vòng đời này bằng cách gắn mỗi kết quả kiểm tra với tài sản, phạm vi được phép, lần quét và quyết định nghiệp vụ tương ứng.

OWASP ZAP thực hiện kiểm tra kỹ thuật. HTQLHDK quản lý điều kiện được phép quét, điều phối lần chạy, tiếp nhận báo cáo, phân tích phát hiện và theo dõi khắc phục. Sự phân tách này giúp tránh coi cảnh báo tự động là kết luận cuối cùng, đồng thời tạo dấu vết để người phụ trách có thể giải thích một quyết định đóng hoặc mở lại phát hiện.

1.2. Mục tiêu và phạm vi

Bảng 1.1. Mục tiêu của bốn chức năng chính

Mã	Chức năng	Kết quả cần đạt
F-01	Tài sản và phạm vi	Lưu website, chủ sở hữu, phiên bản phạm vi, URL cho phép hoặc loại trừ và khung giờ đã phê duyệt.
F-02	Lịch và quét	Tạo kế hoạch, sinh một lần quét cho mỗi kỳ, kiểm điều kiện trước chạy và theo dõi trạng thái ZAP.
F-03	Báo cáo và phát hiện	Kiểm tra báo cáo gốc, tính toàn vẹn, chuẩn hóa cảnh báo, chống nhập trùng và tách mức độ nguồn khỏi mức độ cuối cùng.
F-04	Khắc phục và xác minh	Giao việc, cập nhật tiến độ và bằng chứng, tạo lần quét xác minh, đóng hoặc mở lại theo quyết định ATTT.

Phạm vi lõi dùng một công cụ quét ngoài là OWASP ZAP. Hệ thống không tự phát triển bộ máy dò tìm lỗ hổng, không tự sửa website, không cho quét mục tiêu chưa được phê duyệt và không trao quyền kết luận nghiệp vụ cho tài khoản dịch vụ. Các chức năng chấp nhận rủi ro, thông báo lưu riêng, báo cáo quản trị nâng cao và tích hợp công cụ quét khác có thể xuất hiện trong hồ sơ thiết kế mở rộng nhưng không thuộc mô hình dữ liệu lõi 13 bảng trình bày ở Chương III.

1.3. Cơ sở lý thuyết và thuật ngữ

Tài sản là website hoặc ứng dụng web được quản lý. Phạm vi quét là tập quy tắc Include và Exclude cùng khung giờ cho phép; một phiên bản đã phê duyệt phải được giữ nguyên để có thể truy lại căn cứ của lần quét. Kế hoạch quét quy định chu kỳ hoặc yêu cầu xác minh, còn lần quét là một lần thực hiện cụ thể. Báo cáo nguồn là tệp do

ZAP sinh ra; phát hiện là thực thể nghiệp vụ được chuẩn hóa từ một hoặc nhiều cảnh báo nguồn. Lần xuất hiện liên kết một phát hiện với một lần quét cụ thể.

Mức độ nguồn và độ tin cậy do ZAP đưa ra là dữ liệu tham khảo kỹ thuật. Final Severity là mức độ sau khi chuyên viên ATTT xem xét ngữ cảnh tài sản, bằng chứng và tác động nghiệp vụ. Việc không thấy cảnh báo trong một báo cáo mới chưa đủ để kết luận đã khắc phục: lần quét xác minh còn phải bao phủ đúng mục tiêu, cấu hình và điều kiện so sánh. Hệ thống vì vậy tách trạng thái kỹ thuật của ZAP khỏi trạng thái xử lý phát hiện.

Trong thiết kế dữ liệu, khóa chính nhận diện từng bản ghi; khóa ngoại bảo đảm quan hệ tồn tại; khóa duy nhất ngăn tạo bản ghi có cùng định danh nghiệp vụ. Giao dịch nguyên tử bảo vệ trường hợp nhập báo cáo dở dang. Nhật ký kiểm toán chỉ ghi thêm và lưu thông tin đã che để phục vụ truy vết mà không làm lộ nội dung nhạy cảm.

1.4. Nền tảng kỹ thuật và tình trạng dự án

Bảng 1.2. Nền tảng và trạng thái hiện tại

Thành phần	Thiết kế hoặc hiện vật	Trạng thái
Giao diện	React 19.2 và TypeScript	Đã có nền dự án và kiểm tra cơ bản; màn hình nghiệp vụ đầy đủ chưa hoàn tất.
API	ASP.NET Core/.NET 10, REST/OpenAPI	Có API nền và endpoint kiểm tra sức khỏe; xử lý F-01 đến F-04 chưa hoàn chỉnh.
Worker	Lập lịch và chạy ZAP Automation Framework	Có mã điều phối và kiểm thử đơn vị; mặc định tắt, chưa có nghiệm thu đầu cuối.
Cơ sở dữ liệu	PostgreSQL 17; V001 và bổ sung V002	V001 là lược đồ 27 bảng. V002 bổ sung 3 bảng tự động hóa ZAP trong nhánh làm việc; mô hình 13 bảng là thiết kế đích.
Tệp báo cáo	Kho tệp riêng và metadata SHA-256	Adapter local phục vụ thử nghiệm; kho object và mã hóa production còn cần tích hợp.

Báo cáo phân biệt ba mức: yêu cầu và thiết kế, mã nguồn hoặc migration đã tạo, và tính năng đã được kiểm chứng vận hành. Tài liệu kiến trúc ban đầu chưa có điều phối ZAP; phần bổ sung sau đưa Worker và runner vào phương án mới. Vì phần bổ sung chưa được hợp nhất vào baseline phê duyệt, các mô tả triển khai ZAP trong báo cáo là trạng thái thiết kế/cài đặt hiện có, không phải xác nhận hệ thống đã chạy production.

CHƯƠNG II. PHÂN TÍCH YÊU CẦU

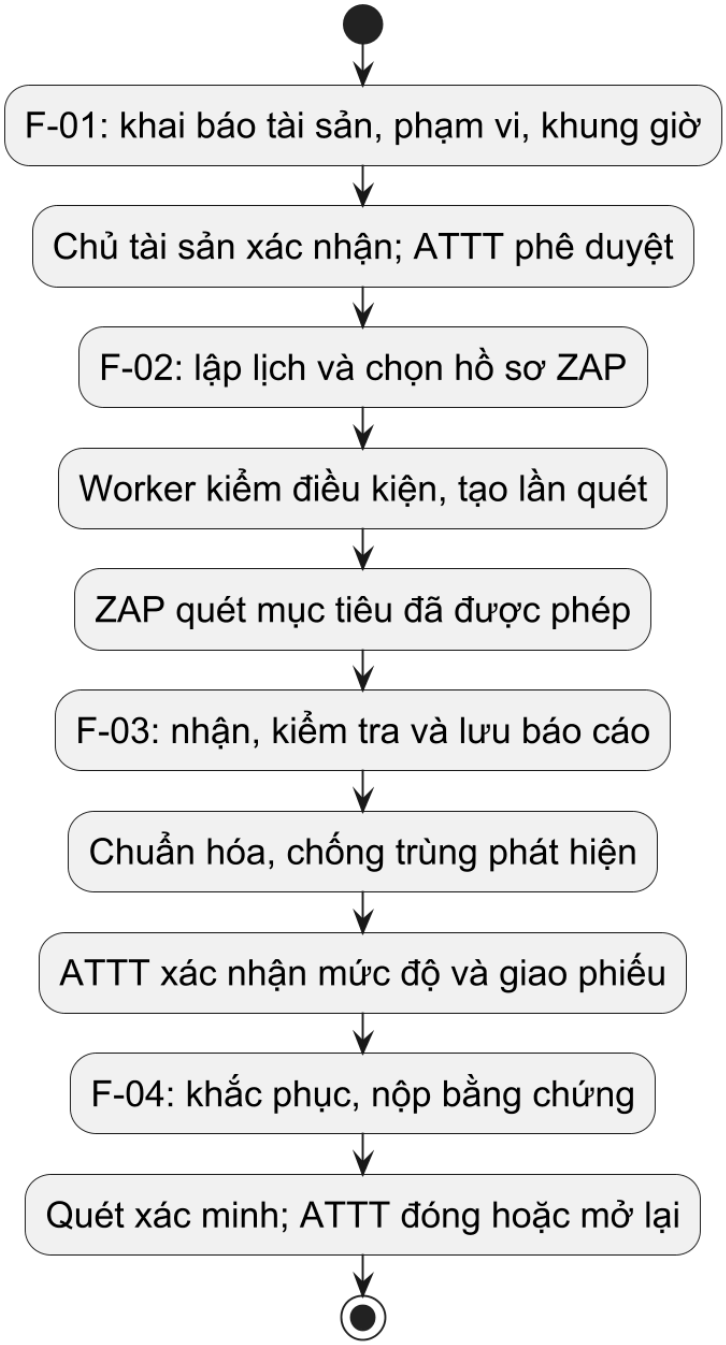
2.1. Đối tượng sử dụng và trách nhiệm

Bảng 2.1. Tác nhân và trách nhiệm

Đối tượng	Trách nhiệm chính	Giới hạn quyền
Chủ tài sản	Khai báo, xác nhận sở hữu, phạm vi, khung giờ và tác động nghiệp vụ.	Không tự phê duyệt phạm vi quét.
Chuyên viên ATTT	Phê duyệt phạm vi/hồ sơ, phân tích phát hiện, xác nhận mức độ, giao việc và kết luận xác minh.	Quyền đọc báo cáo gốc phải đúng tài sản.
Vận hành quét	Cấu hình, theo dõi lịch/runner, xử lý lỗi và dừng khi có thẩm quyền.	Không tự thay đổi mức độ cuối cùng hoặc đóng phát hiện.
Nhóm khắc phục	Sửa lỗi, cập nhật tiến độ, nộp bằng chứng và đề nghị xác minh.	Không tự xác nhận lỗ hổng đã đóng.
Quản trị viên	Quản lý định danh và quyền truy cập.	Không mặc nhiên xem báo cáo gốc.
OWASP ZAP	Quét kỹ thuật và tạo báo cáo.	Không truy cập trực tiếp cơ sở dữ liệu nghiệp vụ.

Bộ lập lịch và Worker là thành phần nội bộ của HTQLHDK, không phải người dùng. Tài khoản dịch vụ chỉ giúp ghi nhận hành động kỹ thuật và không được đăng nhập giao diện hoặc phê duyệt. Mỗi thao tác có quyền theo vai trò, tài sản, nhiệm vụ và trạng thái đối tượng; API phải kiểm lại quyền ngay cả khi giao diện đã ẩn nút thao tác.

2.2. Quy trình nghiệp vụ tổng thể



Hình 2.1. Luồng hoạt động từ tài sản đến xác minh

Quy trình bắt đầu từ tài sản và phạm vi đã được chủ tài sản xác nhận, chuyên viên ATTT phê duyệt. Sau khi lịch và hồ sơ quét có hiệu lực, Worker tạo một lần quét khi đến hạn, kiểm lại điều kiện trước khi khởi chạy ZAP và chỉ chuyển báo cáo hợp lệ vào bước nhập kết quả. ATTT phân tích phát hiện, giao phiếu; nhóm kỹ thuật xử lý rồi đề nghị xác minh. Quyết định đóng hoặc mở lại dựa trên kết quả kiểm tra và mức độ bao phủ của lần quét xác minh.

Luồng trên thể hiện đường đi thành công. Các nhánh từ chối, quá hạn, lỗi ZAP, báo cáo sai định dạng, phát hiện trùng và xác minh không đủ bao phủ được nêu trong từng bảng chức năng dưới đây; không tự động chạy lại một phiên có thể đã gửi yêu cầu tới mục tiêu khi trạng thái thực tế chưa rõ.

2.3. F-01 Quản lý tài sản và phạm vi quét

Bảng 2.2. Luồng xử lý F-01

Bước	Tác nhân và thao tác	Điều kiện hoặc kết quả
1	Chủ tài sản khai báo mã, URL gốc, môi trường, đầu mối và mức quan trọng.	URL hợp lệ, không chứa thông tin đăng nhập; mã tài sản không trùng.
2	Chủ tài sản lập phiên bản phạm vi gồm Include, Exclude và khung giờ.	Quy tắc loại trừ được ưu tiên nếu một URL khớp cả hai loại.
3	Chủ tài sản xác nhận nội dung đề nghị.	Lưu người, thời điểm và phiên bản được xác nhận.
4	ATTT rà soát và phê duyệt hoặc trả lại.	Chỉ phiên bản Approved còn hiệu lực mới được dùng; bản duyệt bất biến.
5	Khi thay đổi, tạo phiên bản mới thay vì sửa bản đã duyệt.	Lần quét cũ vẫn truy lại đúng phạm vi đã sử dụng.

Tài sản ở trạng thái Suspended hoặc Retired không sinh lần quét mới. Việc hai tài sản có URL hoặc miền gần giống nhau là tín hiệu rà soát thủ công, không nên tự động hợp nhất vì quyền sở hữu và phạm vi có thể khác nhau.

2.4. F-02 Lập lịch và điều phối quét

Bảng 2.3. Luồng xử lý F-02

Bước	Tác nhân và thao tác	Điều kiện hoặc kết quả
1	ATTT lập kế hoạch định kỳ hoặc kế hoạch xác minh, chọn phạm vi và hồ sơ ZAP.	Tài sản Active, phạm vi Approved, cấu hình Active và khung giờ hợp lệ.
2	Worker chọn lịch đến hạn và tạo hồ sơ lần quét duy nhất.	Khóa công việc và ràng buộc chống tạo hai lần cho cùng kỳ.
3	Worker kiểm lại điều kiện, tạo kế hoạch Automation Framework và chạy runner cô lập.	Không nhận YAML/lệnh tùy ý; active scan mặc định tắt.
4	Worker theo dõi heartbeat, lease, timeout và yêu cầu dừng.	Trạng thái kỹ thuật tách khỏi trạng thái nghiệp vụ của lần quét.
5	Runner trả báo cáo hoặc lỗi.	Lỗi/timeout phải ghi lý do đã che; không tự retry khi có thể đã quét.

Lịch thủ công vẫn có thể tồn tại khi cờ tự động hóa tắt. Trong lược đồ SQL hiện hành, scan_schedule lưu lịch, scan_occurrence lưu lần quét nghiệp vụ và zap_execution lưu phiên ZAP; mô hình dữ liệu đích 13 bảng gộp các thông tin cần thiết vào scan_plan và scan_run. Hai cách lưu này không được trình bày như cùng một lược đồ đã triển khai.

2.5. F-03 Tiếp nhận báo cáo và phát hiện

Bảng 2.4. Luồng xử lý F-03

Bước	Tác nhân và thao tác	Điều kiện hoặc kết quả
1	Worker nhận báo cáo JSON/HTML từ lần quét hoặc người có quyền nhập báo cáo được phép.	Kiểm kích thước, loại tệp, nguồn, tài sản, host mục tiêu và SHA-256.
2	Lưu tệp gốc bất biến vào kho riêng; ghi metadata.	Không công bố URL tệp hoặc đưa nội dung thô vào log.
3	Tạo lô Received để bộ xử lý F-03 xác thực và chuẩn hóa.	Trường hợp báo cáo lỗi phải từ chối/hoàn tác toàn bộ; không sinh phát hiện nửa vời.
4	Tính dấu vân tay, liên kết cảnh báo với finding và lần xuất hiện.	Một phát hiện có thể xuất hiện qua nhiều lần quét; bản ghi nguồn không bị ghi đè.
5	ATTT đánh giá kết quả và xác nhận Final Severity.	Risk/Confidence nguồn được giữ riêng với quyết định cuối cùng.

Worker tự động hiện mới tạo import_batch ở trạng thái Received; parser nghiệp vụ F-03 đầy đủ chưa được chứng minh hoàn tất. Vì vậy kết quả ZAP được thu nhận không đồng nghĩa các finding đã được chuẩn hóa và đưa vào quy trình khắc phục.

2.6. F-04 Khắc phục và xác minh

Bảng 2.5. Luồng xử lý F-04

Bước	Tác nhân và thao tác	Điều kiện hoặc kết quả
1	ATTT phân công phiếu cho người khắc phục và đặt hạn xử lý.	Người nhận có quyền phù hợp; hạn là quyết định nghiệp vụ, không suy ra từ fixture.
2	Người khắc phục cập nhật nguyên nhân, biện pháp, tiến độ và bằng chứng.	Bằng chứng nhạy cảm lưu riêng; thay đổi có audit.
3	Sau khi sửa, tạo kế hoạch quét xác minh gắn với phiếu.	Dùng phạm vi và hồ sơ hợp lệ; một yêu cầu có căn cứ rõ ràng.
4	ZAP thực hiện lần quét mới; ATTT kiểm mức độ bao phủ và sự tái xuất hiện.	Không kết luận từ việc thiếu cảnh báo khi mục tiêu chưa được bao phủ.

Bước	Tác nhân và thao tác	Điều kiện hoặc kết quả
5	ATTT đóng hoặc mở lại phát hiện, ghi lý do và thời điểm.	Người khắc phục không tự đóng; lịch sử được giữ trong audit.

2.7. Yêu cầu dữ liệu và yêu cầu chất lượng

Bảng 2.6. Dữ liệu vào ra của các chức năng

Chức năng	Dữ liệu vào	Dữ liệu ra
F-01	Tài sản, URL, chủ sở hữu, quy tắc phạm vi, khung giờ.	Tài sản và phiên bản phạm vi đã được duyệt.
F-02	Lịch, cấu hình ZAP, trạng thái tài sản và phạm vi.	Lần quét, trạng thái chạy, lý do lỗi hoặc báo cáo.
F-03	Tệp báo cáo, checksum, metadata lần quét.	Lô tiếp nhận, phát hiện, lần xuất hiện, mức độ nguồn.
F-04	Finding, người phụ trách, hạn, bằng chứng, yêu cầu xác minh.	Phiếu, kết quả xác minh, quyết định đóng/mở lại.

Yêu cầu chất lượng trọng tâm là tính đúng phạm vi, khả năng truy vết, tính toàn vẹn báo cáo và an toàn dữ liệu lỗ hổng. Người dùng chỉ được truy cập phần dữ liệu phù hợp với vai trò, tài sản và nhiệm vụ; API phải thực thi mặc định từ chối. Thao tác ghi cần chống xử lý lặp và dùng giao dịch, đặc biệt khi nhận báo cáo hoặc chuyển trạng thái khắc phục. Thời gian lưu báo cáo, giới hạn tải lên, SLA, RPO/RTO và định mức tải phải được đơn vị sử dụng phê duyệt trước khi triển khai thật; báo cáo không gán số liệu giả cho các chính sách này.

CHƯƠNG III. PHÂN TÍCH VÀ THIẾT KẾ HỆ THỐNG

3.1. Ranh giới hệ thống

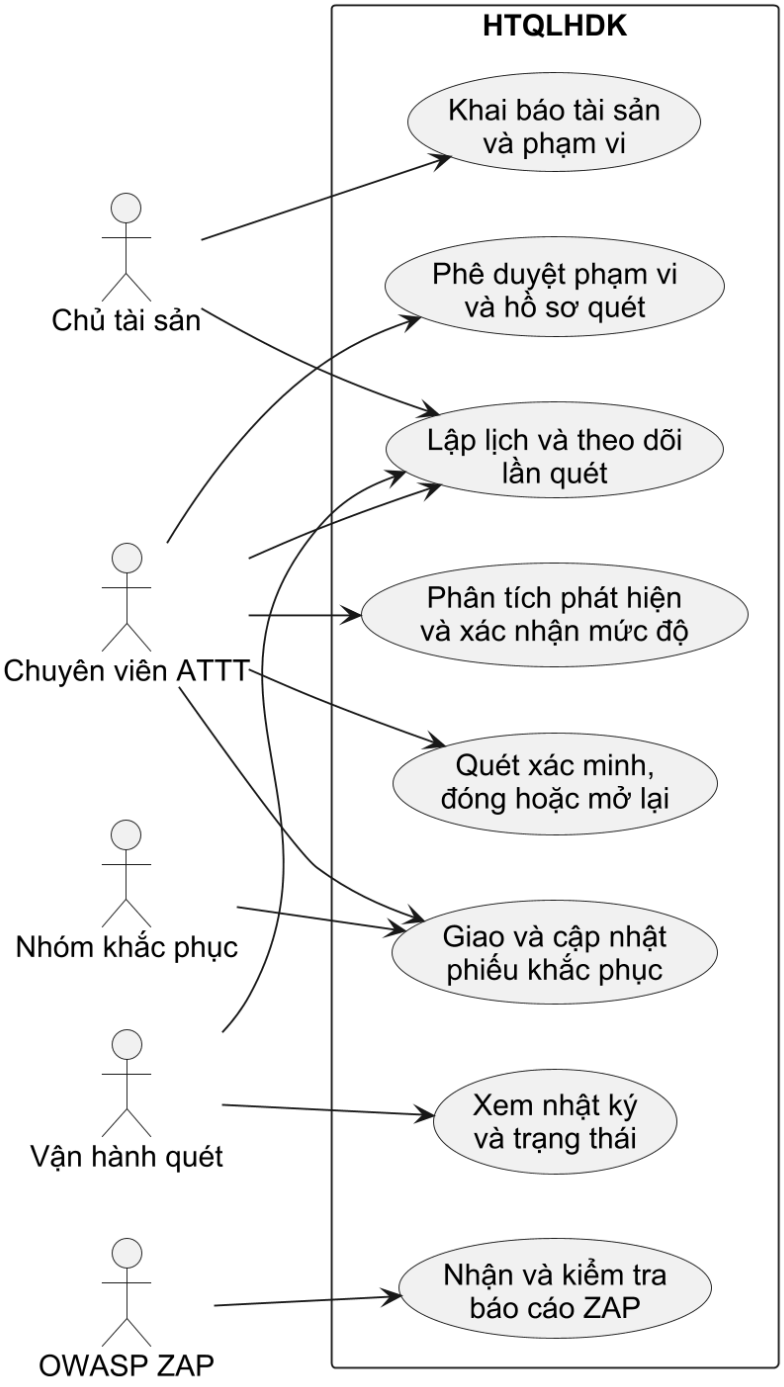
Ranh giới HTQLHDK bao gồm giao diện web, API nghiệp vụ, Worker lập lịch/điều phối và các mô-đun quản lý F-01 đến F-04. PostgreSQL, kho tệp riêng, dịch vụ định danh và quản lý bí mật là phụ thuộc hạ tầng; OWASP ZAP là công cụ quét ngoài ranh giới nghiệp vụ. Website mục tiêu chỉ nhận lưu lượng quét từ runner theo URL, thời gian và cấu hình đã phê duyệt.

Bảng 3.1. Ranh giới và trao đổi dữ liệu

Thành phần	Trong hay ngoài HTQLHDK	Trao đổi được phép
Trình duyệt	Ngoài	Gọi giao diện/API qua HTTPS, không kết nối trực tiếp database hoặc ZAP.
API và Worker	Trong	API xử lý yêu cầu người dùng; Worker xử lý lịch và phiên quét với quyền riêng.
OWASP ZAP	Ngoài	Nhận kế hoạch kỹ thuật và trả báo cáo; không đọc PostgreSQL.
PostgreSQL	Dịch vụ dữ liệu riêng	Lưu trạng thái nghiệp vụ, khóa ngoại, audit và metadata báo cáo.
Kho tệp/IdP/Secrets	Dịch vụ hỗ trợ riêng	Lưu tệp nhạy cảm, xác thực và cấp bí mật theo quyền tối thiểu.

Một ca sử dụng chỉ mô tả mục tiêu mà tác nhân bên ngoài đạt được qua hệ thống. Việc kiểm định dạng tệp, chống trùng, ghi audit hoặc bộ lập lịch nội bộ là bước xử lý của ca sử dụng, không được đặt thành người dùng hay ca sử dụng độc lập. Cách phân tách này tránh nhầm lẫn giữa ranh giới hệ thống, thành phần triển khai và hành vi nghiệp vụ.

3.2. Ca sử dụng



Hình 3.1. Sơ đồ ca sử dụng lõi của HTQLHDK

Bảng 3.2. Các ca sử dụng chính

Mã	Ca sử dụng	Tác nhân	Kết quả
UC-A01	Khai báo tài sản	Chủ tài sản, ATTT	Tài sản ở trạng thái chờ xác nhận/duyệt.
UC-A04	Phê duyệt phạm vi	ATTT	Phiên bản phạm vi Approved hoặc bị trả lại.
UC-S01	Tạo lịch quét	ATTT	Kế hoạch gắn phạm vi và hồ sơ ZAP.
UC-S05	Theo dõi lịch đến hạn	ATTT, vận hành	Biết lần quét đã tạo, bỏ qua hay lỗi.
UC-I01	Tiếp nhận báo cáo	ZAP, vận hành	Báo cáo được kiểm tra và lưu metadata.
UC-I02	Chuẩn hóa phát hiện	ATTT	Finding và lần xuất hiện liên kết đúng lần quét.
UC-F01	Xác nhận mức độ cuối	ATTT	Final Severity có căn cứ và audit.
UC-R01	Giao phiếu khắc phục	ATTT	Phiếu có người phụ trách và thời hạn.
UC-R02	Cập nhật khắc phục	Nhóm khắc phục	Tiến độ, biện pháp và bằng chứng được lưu.
UC-V01	Quét xác minh	ATTT, ZAP	Lần quét mới gắn đúng phiếu và phạm vi.
UC-V02	Đóng hoặc mở lại	ATTT	Quyết định dựa trên coverage và kết quả.

Danh mục ca sử dụng trên tập trung vào bốn chức năng lõi. Hồ sơ thiết kế mở rộng của dự án còn có nhiều ca liên quan chấp nhận rủi ro, thông báo và xuất báo cáo; các ca đó chưa có bảng riêng trong mô hình 13 bảng và không được tính là chức năng đã triển khai. Quan hệ include/extend chỉ nên thể hiện khi có điều kiện dùng lại hoặc nhánh tùy chọn rõ ràng; sơ đồ lõi ưu tiên liên kết tác nhân với mục tiêu nghiệp vụ.

3.3. Luồng hoạt động và trạng thái

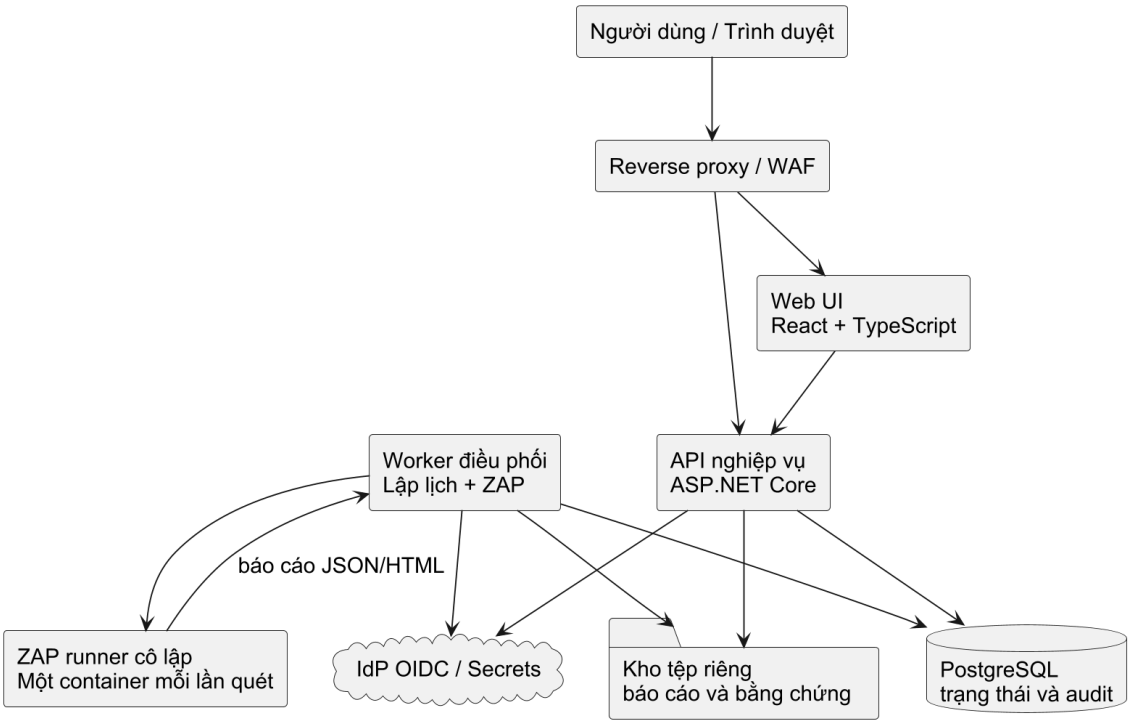
Luồng tổng thể ở Hình 2.1 được triển khai thành bốn chuỗi nghiệp vụ trong các Bảng 2.2–2.5. Các điểm kiểm soát quan trọng là lúc duyệt phạm vi, trước khi runner chạy, lúc nhận báo cáo, lúc chốt Final Severity và khi quyết định đóng. Nếu điều kiện không đạt, tiến trình dừng hoặc chuyển trạng thái lỗi có lý do; không được tiếp tục bằng dữ liệu mặc định.

Bảng 3.3. Trạng thái và điều kiện chuyển của lần quét

Đối tượng	Trạng thái chính	Điều kiện chuyển
Lần quét nghiệp vụ	Planned → Queued → Running → Completed	Lịch đến hạn, được giữ quyền xử lý, runner bắt đầu và báo cáo hợp lệ.
Phiên ZAP kỹ thuật	Queued → Preparing Plan → Starting Runner → Running → Collecting Report → Report Received	Worker ghi snapshot, khởi chạy runner, theo dõi và kiểm tra báo cáo.
Nhánh lỗi	Failed / Timed Out / Cancelled	Lỗi cấu hình, quét, báo cáo, lease hoặc yêu cầu dừng; cần rà soát trước khi chạy lại.
Báo cáo	Received → Validating → Processing → Processed	Bộ xử lý F-03 xác thực toàn bộ và ghi finding trong giao dịch.
Phát hiện	New → Triaged → Assigned → In Progress → Pending Verification → Closed/Reopened	ATTT quyết định mức độ, phân công và kết luận sau quét xác minh.

Trong SQL hiện hành, scan_occurrence và zap_execution là hai bản ghi khác nhau: bản ghi thứ nhất trả lời lần quét nghiệp vụ đã diễn ra như thế nào, bản ghi thứ hai trả lời container ZAP đang ở bước nào. Trạng thái Report Received của Worker chỉ cho biết báo cáo đã được nhận và tạo lô; việc phân tích nội dung F-03 vẫn là một bước tiếp theo. Thiết kế đích 13 bảng sẽ hợp nhất dữ liệu liên quan vào scan_run nhưng vẫn giữ hai trường trạng thái riêng.

3.4. Kiến trúc hệ thống



Hình 3.2. Kiến trúc logic và luồng tích hợp ZAP

HTQLHDK chọn ứng dụng backend đơn khối theo mô-đun để giữ ranh giới F-01 đến F-04 trong một release, đồng thời tách API và Worker thành hai tiến trình vận hành. Giao diện React chỉ hiển thị và gọi REST API. API xác thực, kiểm quyền và xử lý nghiệp vụ; Worker claim công việc bền vững từ PostgreSQL, tạo kế hoạch ZAP, theo dõi runner và nhận báo cáo. Cách tách workload giúp giới hạn quyền khởi chạy container ở Worker và tránh để API công khai giữ Docker socket hoặc khóa ZAP.

Bảng 3.4. Trách nhiệm của các thành phần kiến trúc

Thành phần	Trách nhiệm	Kiểm soát chính
Web UI	Hiển thị tài sản, lịch, phát hiện, phiếu và trạng thái.	Ẩn dữ liệu theo quyền để hỗ trợ trải nghiệm; API vẫn là nơi quyết định quyền.
API	Xử lý lệnh và truy vấn F-01 đến F-04; stream tệp được phép.	Kiểm quyền theo hành động, tài sản và nhiệm vụ; audit thao tác nhạy cảm.
Worker	Claim lịch, tạo lần chạy, sinh plan, giám sát ZAP, kiểm báo cáo.	Identity riêng, lease/heartbeat, timeout, không log payload thô.
ZAP runner	Thực hiện spider/passive/active theo cấu hình và sinh báo cáo.	Container riêng cho mỗi lần quét; active scan chỉ khi được phê duyệt.
PostgreSQL	Lưu dữ liệu nghiệp vụ, quyền, trạng thái và audit.	PK/FK/UNIQUE, giao dịch, migration bất biến và backup.

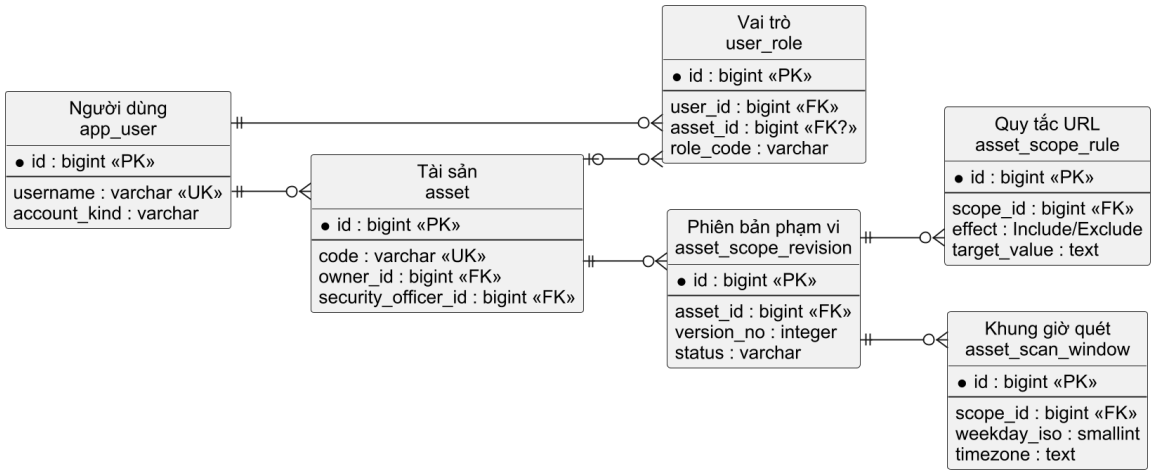
Thành phần	Trách nhiệm	Kiểm soát chính
Kho tệp riêng	Lưu báo cáo gốc và bằng chứng.	Mã hóa, checksum, không công khai đường dẫn; môi trường hiện tại mới có adapter local.

Kênh bên ngoài duy nhất cho người dùng là HTTPS qua reverse proxy/WAF. Database, kho tệp, dịch vụ bí mật và hệ thống quan sát chỉ nằm trong mạng riêng. OIDC là phương án xác thực production của kiến trúc, nhưng bộ API hiện tại vẫn ở mức nền; việc cấu hình nhà cung cấp định danh, định danh bất biến và kiểm quyền theo tài sản phải được hoàn thành trước nghiệm thu. Log chỉ chứa mã định danh, correlation ID, trạng thái và lỗi đã che; không chứa Attack, Evidence, token hoặc toàn bộ URL nhạy cảm.

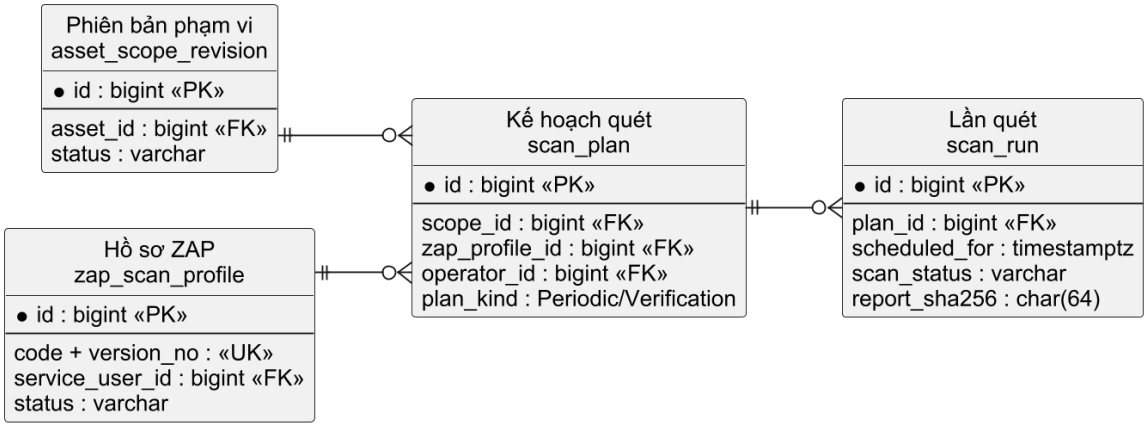
Luồng dữ liệu của một lần quét đi từ bản ghi lịch đến lần quét, phiên ZAP, báo cáo gốc, lô tiếp nhận, phát hiện và phiếu khắc phục. PostgreSQL là nguồn sự thật cho trạng thái, trong khi bytes của báo cáo nằm ở kho tệp riêng và được liên kết bằng object key cùng SHA-256. Việc ghi metadata, hoàn tất lần quét và tạo lô Received cần cùng một giao dịch để tránh trạng thái có báo cáo nhưng không có lô xử lý.

3.5. Thiết kế dữ liệu và sơ đồ quan hệ

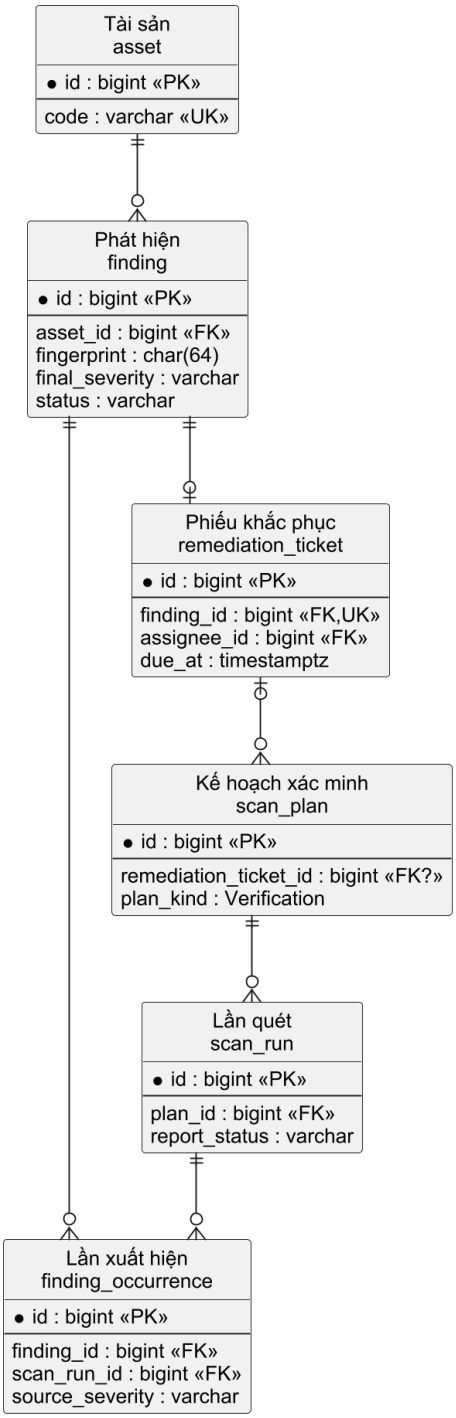
Để giữ mô hình dữ liệu dễ đọc theo phạm vi bốn chức năng, báo cáo dùng ERD đích gồm 13 bảng vật lý. Đây là thiết kế được tinh gọn từ lược đồ hiện hành 27 bảng nền và 3 bảng bổ sung ZAP. Chưa có migration chuyển đổi sang 13 bảng; vì vậy tên scan_plan, scan_run trong các sơ đồ dưới đây là tên thiết kế đích, còn scan_schedule, scan_occurrence, zap_execution, import_batch và zap_artifact là các bảng hiện đang được định nghĩa trong SQL/migration.



Hình 3.3. Sơ đồ quan hệ người dùng, tài sản và phạm vi



Hình 3.4. Sơ đồ quan hệ kế hoạch và lần quét



Hình 3.5. Sơ đồ quan hệ phát hiện, khắc phục và xác minh

Ký hiệu 1–N trên sơ đồ cho biết một bản ghi cha có thể liên kết nhiều bản ghi con; 0–1 biểu thị quan hệ tùy chọn và tối đa một bản ghi. Ba sơ đồ cùng tạo thành ERD của mô hình 13 bảng: app_user và user_role xác định người và quyền; asset là gốc nghiệp vụ; scan_plan/scan_run theo phạm vi và cấu hình ZAP; finding_occurrence nối finding với lần quét; remediation_ticket tạo căn cứ cho kế hoạch xác minh.

Bảng 3.5. Danh sách 13 bảng của mô hình đích

Nhóm	Bảng	Khóa và dữ liệu chính
Định danh	app_user	PK id; UK username; người dùng Human hoặc tài khoản Service.
Định danh	user_role	PK id; FK user_id, asset_id; role_code và hiệu lực cấp/thu hồi.
Tài sản	asset	PK id; UK code; FK owner_id, security_officer_id; URL và trạng thái.
Tài sản	asset_scope_revision	PK id; UK (asset_id, version_no); trạng thái và thời hạn hiệu lực.
Tài sản	asset_scope_rule	PK id; FK scope_id; Include/Exclude và giá trị URL/domain.
Tài sản	asset_scan_window	PK id; FK scope_id; ngày, giờ và múi giờ được phép.
Quét	zap_scan_profile	PK id; UK (code, version_no); cấu hình ZAP và service_user_id.
Quét	scan_plan	PK id; FK scope_id, zap_profile_id; Periodic hoặc Verification.
Quét	scan_run	PK id; FK plan_id; kỳ chạy, trạng thái, báo cáo và SHA-256.
Kết quả	finding	PK id; UK (asset_id, fingerprint); mức độ cuối và trạng thái.
Kết quả	finding_occurrence	PK id; FK finding_id, scan_run_id; mức độ nguồn theo lần quét.
Khắc phục	remediation_ticket	PK id; UK finding_id; người nhận, hạn, tiến độ và bằng chứng.
Truy vết	audit_log	PK id; actor, action, object, outcome và correlation_id.

3.6. Quan hệ giữa các thực thể và các bảng

Quan hệ thực thể phản ánh trách nhiệm nghiệp vụ, còn khóa ngoại là cách hiện thực mối liên kết trong cơ sở dữ liệu. Một tài sản có thể được nhiều người xem theo quyền, nhưng chỉ một owner và một ATTT phụ trách đang được chỉ định trên bản ghi asset. Một tài sản có nhiều phiên bản phạm vi; mỗi phiên bản có nhiều quy tắc và khung giờ. Kế hoạch quét phải tham chiếu chính xác một phiên bản phạm vi và một phiên bản hồ sơ ZAP để các lần quét sau vẫn giải thích được cấu hình đã sử dụng.

Bảng 3.6. Bội số và khóa ngoại giữa các bảng

Quan hệ	Bội số	Khóa ngoại và ý nghĩa
app_user → user_role	1–N	user_role.user_id: một người có nhiều quyền; quyền có thể thu hồi mà không xóa lịch sử.
asset → user_role	1–N tùy chọn	user_role.asset_id: quyền có thể giới hạn theo tài sản; NULL chỉ cho quyền toàn hệ thống được phép.
app_user → asset	1–N theo vai trò	asset.owner_id, security_officer_id, created_by là các vai trò người khác nhau.
asset → asset_scope_revision	1–N	asset_scope_revision.asset_id: mỗi lần sửa phạm vi tạo phiên bản mới.
asset_scope_revision → asset_scope_rule	1–N	asset_scope_rule.scope_id: quy tắc Include/Exclude thuộc đúng phiên bản.
asset_scope_revision → asset_scan_window	1–N	asset_scan_window.scope_id: nhiều khung giờ cho một phiên bản.
app_user → zap_scan_profile	1–N theo vai trò	service_user_id, created_by, approved_by; tài khoản dịch vụ không phê duyệt.
asset_scope_revision → scan_plan	1–N	scan_plan.scope_id giữ căn cứ phạm vi cho mọi lần chạy thuộc plan.
zap_scan_profile → scan_plan	1–N	scan_plan.zap_profile_id giữ phiên bản cấu hình ZAP.
scan_plan → scan_run	1–N	scan_run.plan_id; plan Verification chỉ sinh tối đa một run.
asset → finding	1–N	finding.asset_id; fingerprint duy nhất trong một tài sản.
finding ↔ scan_run	N–N	finding_occurrence có hai FK; mỗi dòng lưu một lần xuất hiện trong một run.
finding → remediation_ticket	1–0..1	remediation_ticket.finding_id là FK và UNIQUE; một finding có tối đa một phiếu hiện hành.
remediation_ticket → scan_plan	1–N tùy chọn	scan_plan.remediation_ticket_id chỉ dùng khi plan_kind = Verification.
app_user → audit_log	1–N tùy chọn	audit_log.actor_id có thể NULL cho sự kiện hệ thống; actor_kind ghi rõ nguồn.

Các đường quan hệ gián tiếp có ý nghĩa đặc biệt. Tài sản của một scan_run được truy theo scan_run → scan_plan → asset_scope_revision → asset; không lưu thêm asset_id trên run vì sẽ tạo nguy cơ hai giá trị mâu thuẫn. Tương tự, một lần xuất hiện không lưu lại asset_id: finding và scan_run đã xác định tài sản, còn ứng dụng phải kiểm tra hai đường này cùng trỏ đến một asset trước khi ghi. Kết quả xác minh truy từ

remediation_ticket → scan_plan loại Verification → scan_run; trạng thái Closed chỉ được đặt sau khi chuyên viên ATTT xác nhận độ bao phủ và lý do quyết định.

Các ràng buộc cần được thực thi đồng thời ở database và ứng dụng. UNIQUE (asset_id, fingerprint) chống trùng finding; UNIQUE (finding_id, scan_run_id) chống ghi cùng một phát hiện hai lần trong một run; UNIQUE (plan_id, scheduled_for) ngăn tạo trùng kỳ quét. CHECK bảo đảm plan định kỳ dùng trường lịch, plan xác minh dùng ticket và thời điểm yêu cầu. Phiên bản phạm vi hoặc profile đã duyệt phải bất biến. Khóa ngoại bảo vệ sự tồn tại của bản ghi cha nhưng không thay thế kiểm quyền, kiểm URL, khung giờ hoặc xác nhận coverage.

Báo cáo nguồn là dữ liệu nhạy cảm nhưng không phải bảng độc lập trong mô hình đích: scan_run lưu object key, SHA-256, kích thước, định dạng và trạng thái; bytes nằm trong kho tệp riêng. audit_log ghi ảnh trước/sau đã che và correlation ID, không dùng làm bảng điều khiển nghiệp vụ. Những dữ liệu có thể tính như phạm vi hiện hành, kỳ quét kế tiếp, first_seen/last_seen, tổng số phát hiện hoặc danh sách phiếu quá hạn được truy vấn từ các bảng gốc thay vì lưu thêm bản sao.

3.7. Thiết kế giao diện và kiểm soát quyền

Bảng 3.7. Màn hình nghiệp vụ ưu tiên

Màn hình	Thông tin và thao tác	Kiểm soát
Tài sản và phạm vi	Danh sách tài sản, phiên bản phạm vi, quy tắc URL, khung giờ, duyệt/từ chối.	Owner và ATTT chỉ xem tài sản liên quan; bản Approved không sửa trực tiếp.
Lịch và lần quét	Lịch, hồ sơ ZAP, kỳ chạy, trạng thái, lỗi đã che và yêu cầu dừng.	Chỉ người được phân công vận hành hoặc ATTT có quyền thao tác.
Báo cáo và phát hiện	Trạng thái lô, cảnh báo, Risk, Confidence, Final Severity và lịch sử xuất hiện.	Báo cáo gốc qua API có kiểm quyền và audit; các trường nhạy cảm được che.
Phiếu khắc phục	Người nhận, hạn, tiến độ, biện pháp, bằng chứng và yêu cầu xác minh.	Assignee chỉ cập nhật phiếu được giao; ATTT quyết định đóng/mở lại.

Giao diện cần thể hiện rõ trạng thái chờ, thành công, từ chối quyền, dữ liệu trùng và lỗi có thể khắc phục. Thời gian hiển thị theo múi giờ người dùng nhưng được lưu bằng UTC cùng thông tin múi giờ cần thiết. Các bảng dữ liệu phải có tìm kiếm, lọc theo tài sản/trạng thái và điều hướng bàn phím. Việc ẩn thao tác ở UI chỉ hỗ trợ người dùng; mọi lệnh vẫn phải được API kiểm tra lại. Hồ sơ giao diện và OpenAPI hiện có ở mức thiết kế, chưa chứng minh toàn bộ màn hình đã hiện thực.

CHƯƠNG IV. PHÁT TRIỂN VÀ THỰC THI

4.1. Cấu trúc mã nguồn và các thành phần đã xây dựng

Mã nguồn được chia thành frontend React/TypeScript, dịch vụ API ASP.NET Core, Worker nền, SQL/migration và bộ kiểm thử. Các tệp thiết kế API, giao diện, ca sử dụng, hoạt động và cơ sở dữ liệu có sẵn để dẫn đường phát triển. Tại thời điểm lập báo cáo, API có endpoint nền và health check; giao diện có project, build và kiểm tra cơ bản; các màn hình và nghiệp vụ F-01 đến F-04 chưa đủ để coi là sản phẩm hoàn chỉnh.

Bảng 4.1. Hiện vật phần mềm và khả năng đã có

Hạng mục	Hiện vật đã thấy	Giới hạn
API	Ứng dụng ASP.NET Core, xử lý lỗi chung, correlation ID, health endpoint.	Chưa có các endpoint nghiệp vụ hoàn chỉnh và kiểm quyền theo tài sản.
Frontend	Ứng dụng React/TypeScript, cấu hình lint/test/build.	Chưa có toàn bộ 32 màn hình thiết kế và luồng nghiệp vụ.
Worker ZAP	Bộ lập lịch, renderer plan, runner Docker, kiểm báo cáo, kho artifact local, repository PostgreSQL.	Cần kiểm thử tích hợp với ZAP và môi trường mục tiêu được phép.
Database	SQL nền, guard/view, V001 và tệp V002 bổ sung ZAP.	Lược đồ 13 bảng chưa được di trú; V002 cần xác minh trên môi trường đích.
Thiết kế	OpenAPI, giao diện, sơ đồ và tài liệu nghiệp vụ.	Hiện vật thiết kế không thay thế bằng chứng chạy đầu cuối.

4.2. Luồng điều phối OWASP ZAP trong mã nguồn

Khi bật cấu hình tự động, Worker lấy lịch đủ điều kiện từ PostgreSQL, giữ lease và tạo lần quét/phiên thực thi. Bộ dựng kế hoạch sinh Automation Framework YAML từ asset, scope và profile đã duyệt; người dùng không tải lên YAML tùy ý. Runner dùng Docker CLI trên host kiểm soát để tạo một container ZAP riêng cho mỗi lần quét. Worker theo dõi heartbeat/timeout và kiểm báo cáo đầu ra về định dạng, host, kích thước và SHA-256 trước khi lưu artifact.

Nếu báo cáo hợp lệ, Worker cập nhật trạng thái lần quét, lưu metadata artifact và tạo import_batch Received trong cùng giao dịch. Việc chuẩn hóa cảnh báo và tạo finding là trách nhiệm của F-03 chưa hoàn tất. Worker không tự xác nhận Final Severity, không tự đóng finding, không tự chạy lại một scan khi không chắc ZAP đã gửi request hay chưa. API không cầm Docker socket hoặc khóa ZAP. Adapter lưu tệp hiện tại dùng filesystem cho local/pilot; production cần kho object riêng và cơ chế mã hóa, cấp secret được phê duyệt.

Bảng 4.2. Kiểm soát trong luồng Worker

Điểm xử lý	Điều kiện hoặc cơ chế	Khi không đạt
Chọn lịch	Lịch, asset, scope và profile đều Active/Approved; đúng khung giờ.	Không dispatch; ghi lý do.
Tạo plan	Cấu hình có phiên bản; secret chỉ là tham chiếu; active scan mặc định tắt.	Từ chối cấu hình không hợp lệ.
Chạy ZAP	Container riêng, giới hạn tài nguyên, không truy cập database.	Dừng/đánh dấu lỗi đã che.
Nhận báo cáo	Đối chiếu định dạng, host, giới hạn kích thước và SHA-256.	Cách ly báo cáo; không tạo finding.
Lease/timeout	Heartbeat nhỏ hơn lease; một worker giữ quyền xử lý.	Failed/Timed Out, rà soát thủ công; không retry mù.

4.3. Cơ sở dữ liệu và quản lý thay đổi

V001 tạo 27 bảng vật lý của mô hình mở rộng, cùng chỉ mục, khóa và một số trigger/view bảo vệ dữ liệu. V002 là phần bổ sung cho tự động hóa ZAP: zap_scan_profile, zap_execution, zap_artifact và các cột gắn profile với lịch. Do đó, 30 bảng là tổng số bảng của bộ SQL/migration khi áp dụng cả V001 và V002; không nên gọi đây là lược đồ 13 bảng. scan_occurrence giữ trạng thái nghiệp vụ, zap_execution giữ trạng thái runner, zap_artifact giữ metadata bất biến và import_batch giữ tiến độ xử lý F-03.

Mô hình 13 bảng tại Chương III là phương án tinh gọn cho tương lai. Việc chuyển đổi đòi hỏi migration riêng, ánh xạ dữ liệu, kiểm tính toàn vẹn, đối chiếu contract API và thử lại toàn bộ workflow. Không được sửa V001 hoặc V002 đã dùng chung để ép khớp mô hình. Migration mới phải có version, checksum, điều kiện trước chạy, bước xác minh, kế hoạch phục hồi và bằng chứng đã chạy trên PostgreSQL thực.

4.4. Kiểm thử và mức độ hoàn thành

Các hồ sơ kiểm tra của dự án ghi nhận 75/75 ca kiểm tra SQL nền đạt trên PostgreSQL 17.5 nhúng; baseline giai đoạn 10 cũng có kết quả build backend, kiểm tra frontend và migration V001 ở môi trường cục bộ. Những kết quả đó chứng minh hiện vật nền tại thời điểm chạy, không chứng minh F-01 đến F-04 đã vận hành đầu cuối hoặc V002/Worker đã được nghiệm thu. Bộ Worker có kiểm thử đơn vị cho lịch, plan, kiểm báo cáo và tham chiếu secret, nhưng báo cáo này không gán tỷ lệ đạt khi chưa có log chạy mới của toàn bộ bộ kiểm thử.

Bảng 4.3. Ma trận mức độ hoàn thành

Nội dung	Đã có	Cần hoàn thành để nghiệm thu
F-01	Yêu cầu, ca sử dụng, ERD và ràng buộc dữ liệu.	API/UI, phân quyền, phê duyệt và kiểm thử phạm vi thật.
F-02	Mã Worker ZAP và tệp V002; logic lịch/runner.	Tích hợp, kiểm thử đồng thời, lease, hủy và mục tiêu staging được phép.
F-03	Thu báo cáo và tạo lô Received ở Worker.	Parser, chuẩn hóa, chống trùng, transaction và kiểm thử dữ liệu sai.
F-04	Thiết kế phiếu, xác minh và quy tắc đóng/mở.	API/UI, bằng chứng, coverage và kiểm thử tách nhiệm vụ.
Vận hành	Cấu hình local, migration, health và tài liệu môi trường.	OIDC, object storage mã hóa, backup/restore, UAT và giám sát production.

CHƯƠNG V. TRIỂN KHAI VÀ KIỂM CHỨNG

5.1. Môi trường và điều kiện triển khai

Dự án phân biệt local, môi trường kiểm thử, staging/UAT và production. Local dùng dữ liệu giả, PostgreSQL container và kho tệp local; môi trường kiểm thử tạo lại dữ liệu để chạy tự động; staging phải gần cấu hình production nhưng dùng dữ liệu giả hoặc đã khử định danh. Production cần PostgreSQL riêng, kho tệp riêng tư, mã hóa, dịch vụ bí mật, định danh OIDC, giám sát và cơ chế khôi phục được đơn vị vận hành phê duyệt. Không đưa fixture, secret local hoặc báo cáo quét thật vào mã nguồn và pipeline.

Bảng 5.1. Ma trận môi trường triển khai

Yếu tố	Local/kiểm thử	Staging/production
Dữ liệu	Dữ liệu giả, miền thử nghiệm, có thể tạo lại.	Dữ liệu đã khử định danh ở staging; production dùng dữ liệu thật theo quyền.
PostgreSQL	Container và migration thử nghiệm.	Database mạng riêng, backup và quyền runtime/migration tách biệt.
Báo cáo	Kho tệp local/pilot.	Kho object private, mã hóa và kiểm tra phục hồi.
Secret	Biến môi trường local không commit.	Secret manager và workload identity; không ghi token vào log/plan.
ZAP	Chỉ quét mục tiêu thử nghiệm được phép.	Runner riêng, allowlist egress, giới hạn tài nguyên, phê duyệt active scan.

Các thông số số lượng lần quét đồng thời, thời gian giữ báo cáo, giới hạn kích thước, SLA, RPO/RTO và tần suất backup chưa được quyết định trong hồ sơ hiện tại. Trước khi chạy ở production, chủ sở hữu hệ thống và đơn vị hạ tầng phải điền các giá trị này, kiểm chứng bằng tải và thử khôi phục, rồi lưu thành cấu hình được kiểm soát thay đổi.

5.2. Trình tự triển khai

Bảng 5.2. Các bước triển khai và kiểm tra

Bước	Thao tác	Dấu hiệu đạt
1	Chuẩn bị mạng riêng, PostgreSQL, kho tệp, IdP, secret store và runner.	Chỉ các kênh cần thiết được mở; không public database hoặc kho báo cáo.
2	Áp dụng V001 trên database sạch; kiểm checksum và số bảng.	Migration Applied và verify đạt; lần chạy lại là no-op.
3	Nếu chọn phương án tự động ZAP, rà soát/phê duyệt rồi áp dụng V002.	Ba bảng và các cột bổ sung tồn tại; trigger/view hoạt động.

Bước	Thao tác	Dấu hiệu đạt
4	Triển khai UI, API và Worker từ cùng bản phát hành.	Health endpoint đạt; Worker mặc định tắt trước khi cấu hình hoàn tất.
5	Tạo tài khoản dịch vụ, hồ sơ ZAP đã duyệt, scope và lịch thử nghiệm.	Secret chỉ ở secret store; profile chỉ lưu tham chiếu.
6	Bật Worker có kiểm soát, chạy một lần quét passive trên website staging được phép.	Có lần quét, báo cáo đúng host/checksum và lô Received, không có dữ liệu nhạy cảm trong log.
7	Hoàn tất F-03/F-04, chạy UAT và kiểm tra khôi phục trước production.	Có bằng chứng đạt tiêu chí ở Bảng 5.3, phê duyệt vận hành.

Không coi bước 6 là nghiệm thu toàn hệ thống: nó chỉ kiểm tra đường đi đến lô Received. Muốn nghiệm thu F-03 và F-04 phải có parser hoàn chỉnh, phân quyền, màn hình nghiệp vụ, transaction tạo finding, quyết định Final Severity, phiếu khắc phục và xác minh. Production không được bật chỉ vì các bài kiểm tra local hoặc build đã đạt.

5.3. Bảo mật, giám sát và sao lưu

Các vùng tin cậy gồm trình duyệt, lớp biên, ứng dụng, runner ZAP, dữ liệu và dịch vụ bảo mật. Giao tiếp đi qua TLS; API kiểm token/phiên và quyền theo tài sản; Worker dùng identity riêng. Runner không có đường nối trực tiếp tới PostgreSQL. Báo cáo và bằng chứng cần nằm trong kho riêng, có checksum, mã hóa và chỉ được tải qua API sau khi kiểm quyền và ghi audit. Thông tin nhạy cảm được che khi hiển thị và bị loại khỏi log.

Quan sát vận hành cần ít nhất trạng thái API/Worker, số lịch đến hạn, số job đang chạy, lỗi lease/heartbeat, timeout, kết quả kiểm báo cáo và độ dài hàng đợi F-03. Mỗi sự kiện dùng correlation ID để nối yêu cầu, lần quét và artifact mà không ghi payload. Cảnh báo phải chỉ rõ mức độ và người phụ trách xử lý, nhưng ngưỡng cảnh báo do đơn vị vận hành quyết định sau khi đo tải thật.

Cơ sở dữ liệu và kho tệp phải được sao lưu đồng bộ về mặt tham chiếu: restore chỉ đạt khi bản ghi báo cáo tìm thấy đúng object có checksum khớp. Cần thử phục hồi theo kịch bản mất database, mất object, migration lỗi và runner mất quyền giữ công việc. Kế hoạch rollback ứng dụng phải tương thích với schema; migration đã áp dụng không được sửa/xóa trực tiếp. Chỉ môi trường local/test được phép tái tạo database từ sạch sau khi xác minh đúng đích.

5.4. Kịch bản kiểm chứng và tiêu chí nghiệm thu

Bảng 5.3. Kịch bản kiểm chứng bắt buộc

Mã	Kịch bản	Kết quả mong đợi
KT-01	Tài sản chưa duyệt hoặc đã tạm dừng đến kỳ quét.	Không chạy ZAP; lưu lý do.
KT-02	URL khớp cả Include và Exclude hoặc nằm ngoài khung giờ.	URL bị loại hoặc lịch bị trì hoãn theo quy tắc được duyệt.
KT-03	Hai Worker chọn cùng kỳ hoặc Worker mất lease.	Chỉ một lần quét hợp lệ; không retry mù phiên đã có thể gửi request.
KT-04	Báo cáo sai định dạng, sai host, quá lớn hoặc sai checksum.	Từ chối/cách ly; không tạo finding nửa vời; lỗi đã che.
KT-05	Nhập cùng báo cáo hoặc cùng phát hiện hai lần.	Không tạo trùng kỳ, lô hoặc lần xuất hiện.
KT-06	Người không có quyền tài sản mở báo cáo gốc.	API từ chối; audit truy cập thất bại không lộ nội dung.
KT-07	Người khắc phục tự đóng phiếu hoặc ATTT đóng khi quét không đủ coverage.	Từ chối chuyển trạng thái; yêu cầu quyết định hợp lệ.
KT-08	Khôi phục database và kho tệp từ backup.	Liên kết artifact và SHA-256 vẫn hợp lệ; đạt RPO/RTO đã phê duyệt.

Biên bản nghiệm thu cần ghi môi trường, phiên bản mã nguồn/migration, cấu hình không bí mật, thời điểm chạy, người thực hiện và kết quả từng kịch bản. Những kịch bản chưa chạy phải để trạng thái chưa kiểm chứng, không đánh dấu đạt dựa trên sơ đồ hoặc mô tả thiết kế. Trước khi dùng dữ liệu thật, phải có phê duyệt mục tiêu quét, cửa sổ thời gian, cấu hình active scan nếu cần và phương án dừng khẩn cấp.

CHƯƠNG VI. KẾT LUẬN

6.1. Kết quả đạt được

Đề tài đã xác định đầy đủ vòng đời quản lý quét lỗ hổng website theo bốn chức năng F-01 đến F-04, từ tài sản và phạm vi được phép đến lịch quét, báo cáo nguồn, phát hiện, phiếu khắc phục và xác minh. Báo cáo đã thống nhất ranh giới hệ thống, tác nhân, ca sử dụng, luồng hoạt động, kiến trúc API/Worker/ZAP và mô hình quan hệ dữ liệu đích. Ba sơ đồ ERD tách theo nhóm nghiệp vụ thể hiện khóa và bội số để có thể đọc cùng bảng quan hệ chi tiết.

Về hiện vật phần mềm, dự án có nền giao diện/API, bộ SQL và migration nền, mã Worker cho tự động hóa ZAP cùng các kiểm tra liên quan. Kiến trúc tách API khỏi quyền điều khiển runner, giữ báo cáo gốc riêng với metadata và phân biệt dữ liệu nguồn ZAP với quyết định cuối cùng của ATTT. Các quyết định này tạo cơ sở để triển khai tiếp mà vẫn kiểm soát phạm vi quét và khả năng truy vết.

6.2. Hạn chế hiện tại

Hệ thống chưa thể được mô tả là hoàn thành vận hành đầu cuối. API và giao diện nghiệp vụ chưa có đủ F-01 đến F-04; Worker mới đưa báo cáo đến lô Received; parser F-03, quy trình khắc phục F-04 và kiểm thử tích hợp còn thiếu. Kho tệp local chưa thay thế kho object mã hóa production. OIDC, phân quyền theo tài sản và chính sách vận hành cần hiện thực và kiểm tra. Mô hình dữ liệu 13 bảng là thiết kế đích, chưa phải lược đồ PostgreSQL đang áp dụng; việc gộp 30 bảng xuống 13 cần migration và kiểm chứng độc lập.

6.3. Hướng hoàn thiện

Ưu tiên tiếp theo là hoàn thiện API/UI F-01, F-02, parser và giao dịch F-03, sau đó triển khai phiếu khắc phục và xác minh F-04. Bộ kiểm thử cần bao phủ quyền truy cập âm tính, lịch đồng thời, báo cáo lỗi, chống trùng, rollback, coverage và khôi phục. Phương án Worker ZAP phải được phê duyệt, chạy thử trên mục tiêu staging được phép, thay kho local bằng kho private được mã hóa và đưa runner lên hạ tầng có quyền tối thiểu. Khi nghiệp vụ đã ổn định, nhóm mới đánh giá migration sang mô hình 13 bảng cùng tác động đối với API, dữ liệu và lịch sử kiểm toán.

Kết luận của báo cáo là HTQLHDK đã có thiết kế nghiệp vụ và kiến trúc đủ rõ để tiếp tục xây dựng, cùng một phần nền và điều phối ZAP đã được hiện thực. Việc nghiệm thu sử dụng thực tế còn phụ thuộc vào hoàn thành bốn chức năng, kiểm thử đầu cuối và các quyết định chính sách/hạ tầng của đơn vị áp dụng.